

Vulnerability in gevent.pywsgi.WSGIServer #1989

Closed

CTFd/CTFd#2435



mukeran opened on Aug 31, 2023 · edited by mukeran

Edits ▾ ⋮

- gevent version: 23.7.0 (pypi)
- Python version: 3.8.15
- Operating System: Linux

[CVE-2023-41419](#) has been assigned to this issue. Fixed in 23.9.0.

Description

Previously, carefully crafted invalid trailers in chunked requests on keep-alive connections might appear as two requests to `gevent.pywsgi`. Because this was handled exactly as a normal keep-alive connection with two requests, the WSGI application should handle it normally. However, if you were counting on some upstream server to filter incoming requests based on paths or header fields, and the upstream server simply passed trailers through without validating them, then this embedded second request would bypass those checks. (If the upstream server validated that the trailers meet the HTTP specification, this could not occur, because characters that are required in an HTTP request, like a space, are not allowed in trailers.) ([source - docs/changes/1989.bugfix](#))

Payload

```
POST /path1 HTTP/1.1
Host: a.com
Transfer-Encoding: chunked
Connection: keep-alive

2
a2
0
Header: value
POST /path2?a=:123 HTTP/1.1
Host: a.com
Connection: close
```



Credit

Fixed by [@jamadden](#).

Reported by Keran Mu ([@mukeran](#)) and Jianjun Chen ([@chenjj](#)), from Tsinghua University and Zhongguancun Laboratory.

jamadden on Aug 31, 2023 · edited by jamadden

Edits ▾

Member



Thank you for your interest in gevent and your bug report. While `gevent.pywsgi` [has never been advertised as an Internet-facing, production-ready implementation](#) and [users have been advised to use something that is, like gunicorn](#), or at the very least a secure reverse proxy, I will prioritize a fix for this issue.



jamadden added a commit that references this issue [on Sep 1, 2023](#)

gevent.pywsgi: Much improved handling of chunk trailers. ...



Verified

2f53c85



jamadden closed this as [completed](#) in [2f53c85](#) [on Sep 2, 2023](#)

jamadden on Sep 2, 2023

Member



gevent 23.9 has been released with tests and a fix for this. Thank you again for the report.

mukeran on Sep 20, 2023

Author



[@jamadden](#) Hi. Sorry for my late response and thanks for your quick fix. Here's a request: According to MITRE's email, if I want to make the CVE public, I have to modify the description of this issue with the (negative) detail of this vulnerability. Is it OK to replace my description with details of the vulnerability since the issue has been fixed?

jamadden on Sep 22, 2023

Member



I don't see why not; [the release notes](#) already include a summary.

mukeran on Sep 22, 2023

Author



OK, thanks.



kenny-skaggs mentioned this [on Sep 30, 2023](#)

[Bump gevent from 22.10.2 to 23.9.1 all-of-us/raw-data-repository#3624](#)



RiRa12621 added a commit that references this issue [on Dec 8, 2023](#)

fix: update gevent dependency ...

Verified

3f71e4f



RiRa12621 mentioned this [on Dec 8, 2023](#)

[fix: update gevent dependency CTFd/CTFd#2435](#)



RiRa12621 added a commit that references this issue [on Dec 8, 2023](#)

fix: update gevent dependency

Unverified e1cc1be

ColdHeat

added a commit that references this issue on Dec 9, 2023

fix: update gevent dependency (#2435)

Verified 7758925

craig8

added a commit that references this issue on Nov 9, 2024

Update gevent to 23.9.1

Verified c47eb77

craig8

mentioned this on Nov 9, 2024

Update gevent to 23.9.1 VOLTTRON/volttron#3192

craig8

added a commit that references this issue on Jan 22, 2025

Update gevent to 23.9.1

bb1ef84

SumoSumir

mentioned this on Sep 25, 2025

Update PYSEC-2023-177.yaml - correcting affected versions pypa/advisory-database#248

rebwang

added a commit that references this issue on Nov 29, 2025

Update gevent to 23.9.1

c209029

Sign up for free

to join this conversation on GitHub. Already have an account? [Sign in to comment](#)

Assignees

No one assigned

Labels

No labels

Type

No type

Projects

No projects

Milestone

No milestone

Relationships

None yet

Development

 Code with agent mode

 fix: update gevent dependency

CTFd/CTFd

Participants

